

OSCORP | EXECUTIVE CYBERSECURITY ASSESSMENT

NIST Cybersecurity Framework 2.0 | Targeted simulated risk assessment | October 2026

1. Executive Summary

Oscorp is a fictional organization of approximately 200 employees. The scenario includes Microsoft Azure, Microsoft 365, Microsoft Defender, Tenable, network segmentation, and backup/recovery capabilities. Material weaknesses in identity and privileged access, centralized monitoring, and incident response create the most urgent opportunities for risk reduction.

Seven scenario-based risks were assessed: **six High and one Moderate**. Three are P1 (urgent), three P2 (near-term), and one P3 (planned). Scores are qualitative analyst judgments, not measured incident probabilities or NIST-prescribed ratings.

2. Scope and Method

The assessment considers selected outcomes across the six CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond, and Recover. It is not a comprehensive evaluation of every CSF outcome. **Current Risk = Likelihood (1–5) × Impact (1–5)**, taking described existing controls into account. Bands: Low 1–4; Moderate 5–9; High 10–16; Critical 17–25. Remediation priority also considers exposure, business impact, dependencies, implementation effort, and expected risk reduction.

3. Findings by CSF 2.0 Function

Function	Principal scenario observation
Govern (GV)	Risk appetite, accountability, policy and supplier oversight are insufficiently formalized.
Identify (ID)	Asset criticality, risk assessment and supplier/data inventories are incomplete or inconsistent.
Protect (PR)	MFA, privileged access safeguards, least privilege and sensitive-data handling require improvement.
Detect (DE)	Centralized log correlation, alert triage, escalation and detection testing are immature.
Respond (RS)	Formal incident response planning, roles, severity criteria and playbooks are absent.
Recover (RC)	Backup and recovery processes exist; cyber-incident recovery effectiveness is not independently validated.

4. Executive Risk Register

ID	Risk domain	L	I	Score /25	Rating	Priority
R-02	Identity & Privileged Access	4	4	16	High	P1
R-04	Monitoring & Detection	4	4	16	High	P1
R-05	Incident Response	4	4	16	High	P1
R-03	Vulnerability Management	3	4	12	High	P2
R-07	Data Protection & Classification	3	4	12	High	P2
R-06	Third-Party Risk	3	4	12	High	P2
R-01	Governance & Risk Management	3	3	9	Moderate	P3

MANAGEMENT DECISIONS & IMPLEMENTATION

5. Recommended Management Decisions

R-02 / P1 — Identity: Enforce MFA; eliminate shared privileged accounts; establish least-privilege and access reviews.

R-04 / P1 — Detection: Centralize priority logs; establish alert triage, escalation, and detection ownership before broad SIEM expansion.

R-05 / P1 — Response: Approve an incident response plan, roles, severity criteria, and priority playbooks.

R-03 / P2 — Vulnerabilities: Establish recurring authenticated scans, remediation SLAs, ownership, and verification.

R-07 / P2 — Data: Begin sensitive-data discovery/classification in Year 1; expand DLP and handling controls in Year 2.

R-06 / P2 — Suppliers: Inventory critical vendors; conduct risk-based diligence and define supplier incident requirements.

R-01 / P3 — Governance: Formalize risk ownership, appetite, policies and management reporting; start enabling activities in Year 1.

6. Proposed Three-Year Improvement Roadmap

Horizon	Focus and indicative activities
Year 1 — Immediate reduction	MFA and privileged access; critical log monitoring; incident response plan/playbooks; vulnerability SLAs; initial data classification; risk owners; critical supplier reviews.
Year 2 — Capability maturity	Broader SIEM coverage; advanced PAM; vulnerability verification; classification-informed DLP; supplier oversight; tabletop exercises.
Year 3 — Optimization	Detection tuning; control effectiveness reviews; governance reporting; supplier reassessment; lessons learned; periodic risk reassessment.

7. Assessment Limitations

This is a simulated portfolio assessment, not a production audit, certification, or evidence-backed compliance opinion. Findings are drawn from the documented fictional environment. Proposed owners, dates, costs, and control improvements have not been approved or implemented. Subcategory references on the following page identify selected relevant NIST CSF 2.0 outcomes; their application to Oscorp is an analyst interpretation.

8. Traceability

Risk IDs, scores, priorities and recommendations align with the companion *Oscorp Cybersecurity Risk Analysis — CSF 2.0 Aligned*. The detailed analysis provides the risk narratives, described existing controls, and outcome-by-outcome rationale. The risk management workbook tracks proposed actions and planning assumptions.

APPENDIX | SELECTED CSF 2.0 OUTCOME MAPPINGS

The following subcategories are selected as relevant to each scenario, not as evidence of compliance or an exhaustive CSF assessment.

R-01 — Governance

GV.RM-02, GV.RM-06, GV.RR-02, GV.PO-01, ID.AM-05

R-02 — Identity and access

PR.AA-01, PR.AA-03, PR.AA-05

R-03 — Vulnerability management

ID.RA-01, ID.RA-05, ID.RA-06

R-04 — Monitoring and detection

PR.PS-04, DE.CM-01, DE.CM-09, DE.AE-03, DE.AE-08

R-05 — Incident response

ID.IM-04, RS.MA-01, RS.MA-03, RS.MA-04, RS.AN-07

R-06 — Third-party risk

GV.SC-01, GV.SC-04, GV.SC-05, GV.SC-06, GV.SC-07, GV.SC-08

R-07 — Data protection

ID.AM-07, PR.DS-01, PR.DS-02, PR.DS-10

Framework Reference

NIST, *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29 (2024), Appendix A. <https://doi.org/10.6028/NIST.CSWP.29>